



# SentinelAI

แพลตฟอร์มป้องกันข้อมูลลับองค์กรรั่วไหลสู่ AI  
AI Data Loss Prevention (AI-DLP) for the Generative AI Era

เอกสารคอนเซ็ปต์และแผนธุรกิจ (Business & Technical Concept)

|                      |                                                                                |
|----------------------|--------------------------------------------------------------------------------|
| เวอร์ชันเอกสาร:      | 1.0                                                                            |
| วันที่จัดทำ:         | 18 กรกฎาคม 2569                                                                |
| โมเดล AI ที่ใช้:     | BytePlus ModelArk (Dola-Seed, Document/Vision Understanding, Seed-Translation) |
| กลุ่มลูกค้าเป้าหมาย: | องค์กร/บริษัทที่มีข้อมูลลับ (การเงิน, กฎหมาย, สุขภาพ, เทคโนโลยี)               |

# สารบัญ

- บทสรุปผู้บริหาร (Executive Summary)
- ปัญหาที่แก้ — ทำไมองค์กรถึงต้องการสิ่งนี้ "ตอนนี้"
- คอนเซ็ปต์หลักของ SentinelAI
- ระบบทำงานอย่างไร — เส้นทางการดักจับข้อมูล (Interception Flow)
- สถาปัตยกรรมระบบและส่วนประกอบ
- โมดูลของแพลตฟอร์มทั้ง 7 โมดูล
- การจัดประเภทข้อมูลลับ (Data Classification Engine)
- โมเดล BytePlus ที่นำมาใช้จริงในแต่ละจุด
- โครงร่างหน้าจอ (Wireframe)
- โมเดลธุรกิจและการตั้งราคา
- แผนพัฒนา (Roadmap) และตัวชี้วัด
- การปฏิบัติตามกฎหมาย (PDPA) และความเป็นส่วนตัว
- ความเสี่ยงและข้อควรระวัง

## 1. บทสรุปผู้บริหาร

SentinelAI คือแพลตฟอร์มความปลอดภัยระดับองค์กรที่ป้องกัน "ข้อมูลลับรั่วไหลสู่เครื่องมือ AI สาธารณะ" — เมื่อติดตั้งแล้ว ระบบจะสแกนและจัดประเภทไฟล์ที่อ่อนไหว (ข้อมูลการเงิน สัญญา ซอร์สโค้ด ข้อมูลลูกค้า) และดักจับทันทีที่พนักงานพยายามอัปโหลด วาง (paste) หรือพิมพ์ข้อมูลลับเหล่านั้นลงใน ChatGPT, Gemini, Claude, Copilot หรือเว็บ AI อื่น ๆ แล้วแสดงการแจ้งเตือน บล็อก หรือปิดบังข้อมูลอัตโนมัติตามนโยบายองค์กร

### คุณค่าหลัก 3 ข้อ:

- มองเห็น (Visibility): องค์กรรู้ว่าพนักงานเอาข้อมูลอะไรไปป้อน AI บ้าง — ปัจจุบันส่วนใหญ่ "ตาบอด" เรื่องนี้
- ควบคุม (Control): ตั้งนโยบายได้ว่าข้อมูลประเภทไหนห้ามออก บล็อกก่อนหลุด ไม่ใช่ตามสลิปที่หลัง
- พิสูจน์ได้ (Compliance): มีหลักฐาน Log ครบสำหรับ PDPA / ISO 27001 / มาตรฐานการเงิน

จุดต่างจาก DLP แบบเดิม: DLP รุ่นเก่าเน้นบล็อก USB/อีเมล แต่ไม่เข้าใจ "บริบท" ของการสนทนากับ AI — SentinelAI ใช้โมเดล AI (BytePlus) มาเข้าใจเนื้อหาเชิงความหมาย จึงจับได้แม้พนักงานจะดัดแปลง คัดลอกบางส่วน หรือถ่ายรูปหน้าจอส่งเข้าไป

## 2. ปัญหาที่แก้ — ทำไมองค์กรต้องการสิ่งนี้ตอนนี้

### 1 ใน 5

ของพนักงานเคยวางข้อมูลบริษัท  
ลง AI สาธารณะ

### Shadow AI

พนักงานใช้ AI เองโดยองค์กร  
ไม่รู้/ไม่อนุมัติ

### ถาวร

ข้อมูลที่หลุดเข้า AI อาจถูกใช้  
เทรน/กู้คืนไม่ได้

### PDPA

โทษปรับสูงหากข้อมูลส่วนบุคคล  
รั่ว

### 2.1 สถานการณ์จริงที่เกิดขึ้นในองค์กร

- พนักงานฝ่ายการเงินวางงบการเงินที่ยังไม่ประกาศลง ChatGPT เพื่อขอสรุป → ความลับทางธุรกิจหลุด
- โปรแกรมเมอร์วางซอร์สโค้ดที่มี API Key / รหัสลับลง AI เพื่อ debug → ความลับทางเทคนิคหลุด
- ฝ่าย HR วางข้อมูลเงินเดือน/บัตรประชาชนพนักงานลง AI เพื่อทำตาราง → ผิด PDPA ทันที
- ฝ่ายกฎหมายอัปโหลดสัญญาลับของลูกค้าเพื่อสรุป → ผิดสัญญารักษาความลับ (NDA)

**ช่องว่างสำคัญ:** เครื่องมือความปลอดภัยเดิม (Firewall, Antivirus, DLP รุ่นเก่า) ไม่ได้ออกแบบมาเพื่อ "การสนทนากับ AI" ที่เกิดผ่านเบราว์เซอร์และแอปเดสก์ท็อป — ข้อมูลไหลออกในรูปข้อความที่พิมพ์/วาง ซึ่งเครื่องมือเดิมมองไม่เห็นหรือแยกไม่ออกว่าอันไหนลับ อันไหนทั่วไป

### 3. คอนเซ็ปต์หลักของ SentinelAI

SentinelAI ทำงานบน 3 ชั้นป้องกัน (Defense Layers) ที่ทำงานร่วมกัน:

| ชั้น                                        | ทำหน้าที่                                                                                                   | ติดตั้งที่ไหน                                              |
|---------------------------------------------|-------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|
| 1. Discover & Classify<br>(ค้นหา+จัดประเภท) | สแกนไฟล์ในเครื่อง/เซิร์ฟเวอร์/คลาวด์ ระบุว่าไฟล์ไหนลับระดับใด แล้วติด "ฉลาก" (Label) ให้ข้อมูล              | Agent บนเครื่อง + ตัวเชื่อม Cloud (Google Drive, OneDrive) |
| 2. Monitor & Intercept<br>(เฝ้า+ดักจับ)     | เฝ้าช่องทางที่ข้อมูลอาจไหลออกสู่ AI: ช่องพิมพ์บนเว็บ AI, การวาง, การอัปโหลดไฟล์, การแนบรูป                  | Browser Extension + Endpoint Agent                         |
| 3. Decide & Act<br>(ตัดสินใจ+ลงมือ)         | ใช้ AI ประเมินความเสี่ยงตามบริบท แล้วเลือกการกระทำ: ปล่อยผ่าน / เตือน / ปิดบังบางส่วน / บล็อก และบันทึก Log | Policy Engine บน Cloud/On-Premise                          |



**หลักการออกแบบ:** "ปกป้องโดยไม่ขวางการทำงาน" — พนักงานยังใช้ AI เพิ่มประสิทธิภาพได้ตามปกติ ระบบจะเข้ามาแทรกเฉพาะเมื่อตรวจพบข้อมูลลับจริง ๆ เท่านั้น เพื่อไม่ให้พนักงานหาทางหลบเลี่ยงระบบ

### 4. ระบบทำงานอย่างไร — เส้นทางการดักจับ (Interception Flow)

ตัวอย่าง: พนักงานพยายามวางงบการเงินลง ChatGPT

- พนักงานเปิด chatgpt.com แล้ววาง (Ctrl+V) เนื้อหาการเงิน
- Browser Extension** ดักเหตุการณ์ paste/typing ก่อนข้อความถูกส่ง
- ข้อความถูกส่งไปที่ **Local Classifier** (โมเดลเบา ทำงานในเครื่อง) ตรวจสอบเบื้องต้นว่าเข้าข่ายลับหรือไม่ — เพื่อความเร็วและความเป็นส่วนตัว
- ถ้าเข้าข่ายเสี่ยง ส่งต่อให้ **AI Policy Engine** (ใช้โมเดล BytePlus reasoning) ประเมินเชิงบริบท: นี่คือข้อมูลการเงินภายในที่ยังไม่เปิดเผยจริงหรือไม่ ระดับความเสี่ยงเท่าไร
- Policy Engine เทียบกับ "นโยบายองค์กร" แล้วตัดสินใจการกระทำ
- แสดงผลต่อพนักงานทันที (ดูตัวอย่างกล่องแจ้งเตือนด้านล่าง) และบันทึกเหตุการณ์ลง Audit Log

🚫 SentinelAI — ตรวจพบข้อมูลลับ

เนื้อหาที่คุณกำลังจะส่งไปยัง ChatGPT มีลักษณะเป็น **ข้อมูลการเงินภายใน (Confidential)**

การส่งข้อมูลนี้ออกนอกองค์กรถูกจำกัดตามนโยบายบริษัท

บล็อกการส่ง

ขออนุมัติจากหัวหน้า

ยกเลิก

เหตุการณ์นี้ถูกบันทึกเพื่อการตรวจสอบ • เหตุผล: พบตัวเลขงบดุล + คำว่า "ยังไม่ประกาศ"

## โหมดการตอบสนอง (Action Modes) ที่ตั้งค่าได้ต่อประเภทข้อมูล

Monitor

บันทึกอย่างเดียว ไม่ขวาง

Warn

เตือนแต่ให้ผ่านได้ถ้ายืนยัน

Redact

ปิดบังเฉพาะส่วนลับแล้วให้ส่ง

ที่เหลือ

Block

ห้ามส่งเด็ดขาด

5. สถาปัตยกรรมระบบและส่วนประกอบ

| ส่วนประกอบ          | หน้าที่                                                                      | เทคโนโลยีแนะนำ                              |
|---------------------|------------------------------------------------------------------------------|---------------------------------------------|
| Endpoint Agent      | สแกนไฟล์ในเครื่อง, ฝ้าคลิปปอร์ด/การอัปโหลด, บังคับนโยบายระดับเครื่อง         | Go / Rust (เบา, ข้ามแพลตฟอร์ม Win/Mac)      |
| Browser Extension   | ดักการพิมพ์/วาง/แนบไฟล์บนเว็บ AI, แสดงป๊อปอัปเตือน                           | Chrome/Edge Extension (Manifest V3)         |
| Local Classifier    | คัดกรองเบื้องต้นในเครื่อง (Pattern + โมเดลเบา) เพื่อความเร็ว/ความเป็นส่วนตัว | Regex + ONNX small model / Embedding        |
| AI Policy Engine    | ประเมินความเสี่ยงเชิงบริบทด้วย LLM, ตัดสินการกระทำตามนโยบาย                  | BytePlus ModelArk API (Dola-Seed reasoning) |
| Admin Console       | ตั้งนโยบาย, ดูแดชบอร์ด, จัดการเหตุการณ์, ออกรายงาน                           | Next.js + Tailwind                          |
| Backend + Audit Log | เก็บเหตุการณ์, ผู้ใช้, นโยบาย, รายงาน (เข้ารหัส)                             | Python FastAPI / Node + PostgreSQL          |
| Cloud Connector     | สแกนไฟล์บน Google Drive / OneDrive / SharePoint                              | OAuth API ของแต่ละบริการ                    |

**ตัวเลือกการติดตั้ง:** รองรับทั้ง Cloud (SaaS) สำหรับ SME ที่ต้องการเริ่มเร็ว และ On-Premise / Private Cloud สำหรับองค์กรใหญ่/ธนาคารที่ข้อมูลห้ามออกนอกองค์กร — โดยรันโมเดลผ่าน BytePlus แบบ private endpoint หรือ deploy ในองค์กรได้

5.1 หลักการความเป็นส่วนตัวของตัวระบบเอง (Privacy-by-Design)

- การคัดกรองขั้นแรกทำในเครื่อง (On-device) — ข้อมูลดิบไม่ออกจากเครื่องถ้าไม่จำเป็น
- เมื่อต้องส่งให้ AI ประเมิน จะส่งเฉพาะส่วนที่จำเป็น และ/หรือ ปิดบัง PII ก่อน (Tokenize)
- ตัวระบบต้องไม่กลายเป็นช่องรั่วเสียเอง — เข้ารหัสทุกการส่งข้อมูล และไม่เก็บเนื้อหาลับไว้เกินจำเป็น

6. โมดูลของแพลตฟอร์มทั้ง 7 โมดูล

| #  | โมดูล                           | รายละเอียด                                                                                               |
|----|---------------------------------|----------------------------------------------------------------------------------------------------------|
| M1 | Data Discovery & Classification | สแกนไฟล์ทั้งเครื่อง/คลาวด์ จัดประเภทและติดฉลากความลับอัตโนมัติ                                           |
| M2 | AI Channel Monitor              | เฝ้าเว็บ AI และแอปยอดนิยม (ChatGPT, Gemini, Claude, Copilot, DeepSeek ฯลฯ) รวมถึงการ paste/upload/แนบรูป |

|    |                               |                                                                                                            |
|----|-------------------------------|------------------------------------------------------------------------------------------------------------|
| M3 | Policy Engine                 | สร้างกฎ: ใคร/ข้อมูลประเภทใด/ช่องทางใด → ทำอย่างไร (Monitor/Warn/Redact/Block) แยกตามแผนก/ตำแหน่ง           |
| M4 | Real-time Alert & Redaction   | ป๊อปอัปเตือนพนักงาน + ปิดบังข้อมูลลับอัตโนมัติ + ขั้นตอนขออนุมัติ (Approval Workflow)                      |
| M5 | Admin Dashboard & Analytics   | ภาพรวมเหตุการณ์ทั้งองค์กร, แผนกเสี่ยง, ประเภทข้อมูลที่พยายามหลุดบ่อย, เทรนด์รายสัปดาห์                     |
| M6 | Audit Log & Compliance Report | บันทึกทุกเหตุการณ์ (ใคร-เมื่อไหร่-อะไร-ผลลัพธ์) ออกรายงานสำหรับ PDPA/ISO 27001 ได้                         |
| M7 | Employee Coaching             | แทนการลงโทษ ระบบให้ความรู้พนักงานทันทีเมื่อทำผิด (เช่น "ควรใช้ AI ภายในองค์กรแทน") ลดพฤติกรรมเสี่ยงระยะยาว |

## 7. การจัดประเภทข้อมูลลับ (Data Classification Engine)

หัวใจของความแม่นยำ ระบบใช้ 3 เทคนิคผสมกัน เพื่อลดทั้ง False Positive (เตือนผิด) และ False Negative (ปล่อยหลุด):

| เทคนิค                       | ตรวจจับอะไร                                                                                                                |
|------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| 1. Pattern / Regex           | รูปแบบตายตัว: เลขบัตรประชาชน 13 หลัก, เลขบัญชี, เลขบัตรเครดิต, API Key, อีเมล                                              |
| 2. Fingerprinting            | เอกสารต้นฉบับที่องค์กรระบุว่ามี (เช่น เทมเพลตสัญญา, ไฟล์บ) — จับได้แม้ถูกคัดลอกบางส่วน                                     |
| 3. AI Semantic Understanding | เข้าใจ "ความหมาย" — จับข้อมูลลับที่ไม่มีรูปแบบตายตัว เช่น กลยุทธ์ธุรกิจ ข้อมูลควมรวมกิจการ บทสนทนาลับ โดยใช้โมเดล BytePlus |

### 7.1 ระดับชั้นความลับ (Classification Labels)

**Public** ข้อมูลทั่วไป ไม่จำกัด    **Internal** ใช้ภายในองค์กร    **Confidential** ลับ จำกัดการเข้าถึง    **Restricted** ลับ ที่สุด ห้ามออกนอกองค์กรเด็ดขาด

### 7.2 ครอบคลุมข้อมูลหลายรูปแบบ (Multimodal)

- ข้อความ/เอกสาร: Word, PDF, Excel, ข้อความที่พิมพ์/วาง
- รูปภาพ: ภาพถ่ายหน้าจอเอกสารลับ, สลิป, บัตรประชาชน — ใช้ Vision/OCR understanding
- โค้ด: ซอร์สโค้ดที่มีความลับ (Secrets, Credentials)
- หลายภาษา: ตรวจได้ทั้งไทย/อังกฤษ/จีน ผ่าน Seed-Translation + reasoning

## 8. โมเดล BytePlus ที่นำมาใช้จริงในแต่ละจุด

หมายเหตุความถูกต้อง: ตามที่ตรวจสอบในแคตตาล็อก ModelArk ปัจจุบัน **ไม่มีโมเดล security/guard เฉพาะทางแบบสแตนด์อโลน** (เช่น ทำนอง Llama Guard) — SentinelAI จึงออกแบบให้ "ประยุกต์" โมเดล understanding/reasoning ที่มีอยู่จริงมาทำหน้าที่ความปลอดภัย ร่วมกับตรรกะ/นโยบายที่เราเขียนเอง ส่วนงานคัดกรองแบบกฎตายตัวใช้ Regex/Fingerprint ที่ไม่ต้องพึ่งโมเดล

| โมเดล/ความสามารถ BytePlus   | ใช้ทำอะไรใน SentinelAI                                                           |
|-----------------------------|----------------------------------------------------------------------------------|
| Dola-Seed (reasoning/agent) | ประเมินเชิงบริบทว่าเนื้อหาลับจริงไหม + ตัดสินใจตามนโยบาย (สมองของ Policy Engine) |
| Document Understanding      | อ่าน/เข้าใจ PDF-สัญญา-เอกสาร เพื่อหา PII และเนื้อหาลับ                           |



|                              |                                                                             |
|------------------------------|-----------------------------------------------------------------------------|
| Vision / Image Understanding | ตรวจภาพถ่ายหน้าจอ/สลิป/บัตร ที่พนักงานพยายามแนบเข้า AI (OCR + เข้าใจภาพ)    |
| Seed-Translation             | ทำให้ตรวจจับข้อมูลกลับได้หลายภาษาพร้อมกัน                                   |
| Vector / Embedding           | ทำ Fingerprint เอกสารลับ และค้นความคล้ายเชิงความหมาย (จับเนื้อหาที่ดัดแปลง) |

9. โครงร่างหน้าจอ (Wireframe)

SentinelAI — Admin Dashboard

1,240

เหตุการณ์ตรวจพบ (30 วัน)

87

บล็อกการรั่วไหล

การเงิน

แผนกเสี่ยงสูงสุด

96%

เครื่องพนักงานที่มี Agent

| เวลา  | พนักงาน   | ปลายทาง AI | ประเภทข้อมูล     | การกระทำ |
|-------|-----------|------------|------------------|----------|
| 10:24 | somchai.k | ChatGPT    | งบการเงิน        | บล็อก    |
| 09:58 | naree.p   | Gemini     | บัตร ปชช. ลูกค้า | ปิดบัง   |
| 09:12 | dev.arm   | Claude     | API Key          | บล็อก    |
| 08:40 | hr.mint   | Copilot    | เอกสารภายใน      | เตือน    |

หน้าตั้งนโยบาย (Policy Builder)

ถ้า ประเภทข้อมูล = Restricted และ ปลายทาง = เว็บ AI สาธารณะ → การกระทำ = บล็อก

ถ้า ประเภท = Confidential และ แผนก = การตลาด → เตือน + ขออนุมัติหัวหน้า

ถ้า พบ PII (บัตร ปชช./เบอร์) ทุกกรณี → ปิดบังอัตโนมัติ

## 10. โมเดลธุรกิจและการตั้งราคา

คิดราคาแบบ ต่อผู้ใช้ต่อเดือน (Per Seat) ซึ่งเป็นมาตรฐานของตลาดซอฟต์แวร์ความปลอดภัยองค์กร

| แพ็คเกจ    | เหมาะกับ          | ฟีเจอร์หลัก                                                    | ราคาแนะนำ                          |
|------------|-------------------|----------------------------------------------------------------|------------------------------------|
| Starter    | SME 10–50 คน      | Browser Extension + คัดกรองพื้นฐาน + แดชบอร์ด                  | 150–250 บาท/คน/เดือน               |
| Business   | บริษัท 50–500 คน  | + Endpoint Agent + AI Semantic + Cloud Connector + รายงาน PDPA | 350–550 บาท/คน/เดือน               |
| Enterprise | องค์กรใหญ่/ธนาคาร | + On-Premise + SSO + SIEM Integration + SLA + ทีมดูแล          | ตกลงตามขนาด (เริ่ม 300,000 บาท/ปี) |

### 10.1 ช่องทางรายได้เสริม

- ค่าติดตั้ง/วางระบบครั้งแรก (Onboarding) สำหรับ Enterprise
- บริการ Compliance Audit รายปี (ช่วยเตรียมเอกสาร PDPA/ISO)
- ขายผ่านพาร์ตเนอร์ (MSP/บริษัท IT) แบบ Reseller

### 10.2 เหตุผลที่โมเดลนี้น่าลงทุน

ตลาด DLP และ AI Security กำลังโตเร็วเพราะทุกองค์กรเริ่มใช้ AI แต่ยังไม่มีเครื่องมือคุม — และในไทยยังแทบไม่มีผู้เล่นเฉพาะทางที่เข้าใจภาษาไทย + PDPA + เชื่อมกับ AI ยอดนิยม การเป็นเจ้าแรก ๆ ที่โฟกัสตลาดนี้คือข้อได้เปรียบ ต้นทุนหลักคือค่า LLM API ซึ่งเรียกใช้เฉพาะกรณีเสี่ยง (ส่วนใหญ่กรองด้วย Regex ในเครื่องฟรี) ทำให้ Margin ดี

## 11. แผนพัฒนา (Roadmap) และตัวชี้วัด

| เฟส              | ขอบเขต                                                                                                    | ระยะเวลา    |
|------------------|-----------------------------------------------------------------------------------------------------------|-------------|
| เฟส 1 — MVP      | Browser Extension + Regex/Pattern classifier + ดักจับ paste/upload บนเว็บ AI หลัก 3 ตัว + แดชบอร์ดพื้นฐาน | 6–8 สัปดาห์ |
| เฟส 2 — AI Brain | เชื่อม BytePlus reasoning + Policy Engine + โหมด Warn/Redact/Block + Audit Log                            | 5–6 สัปดาห์ |
| เฟส 3 — Endpoint | Endpoint Agent สแกนไฟล์ในเครื่อง + Document/Vision understanding + Multimodal                             | 6–8 สัปดาห์ |

|                    |                                                             |             |
|--------------------|-------------------------------------------------------------|-------------|
| เฟส 4 — Enterprise | Cloud Connector + SSO + รายงาน PDPA/ISO + On-Premise + SIEM | 6-8 สัปดาห์ |
|--------------------|-------------------------------------------------------------|-------------|

11.1 ตัวชี้วัดความสำเร็จ (KPI)

| KPI                                              | เป้าหมาย                                                    |
|--------------------------------------------------|-------------------------------------------------------------|
| อัตราการตรวจจับข้อมูลลับได้จริง (Detection Rate) | ≥ 95% ของเคสทดสอบ                                           |
| อัตราเตือนผิดพลาด (False Positive)               | ≤ 5% (สำคัญมากต่อการยอมรับของพนักงาน)                       |
| เวลาตอบสนอง (Latency) ต่อการตรวจ 1 ครั้ง         | < 1 วินาที (กรองในเครื่อง) / < 3 วินาที (เมื่อต้องเรียก AI) |
| ความครอบคลุมเครื่องพนักงาน                       | ≥ 90% ของอุปกรณ์ในองค์กร                                    |

## 12. การปฏิบัติตามกฎหมาย (PDPA) และความเป็นส่วนตัว

**ประเด็นละเอียดอ่อน:** ระบบนี้ "เฝ้าดู" การทำงานของพนักงาน จึงต้องออกแบบให้ถูกกฎหมายและโปร่งใส ไม่ใช่การสอดแนม (Surveillance) มิฉะนั้นตัวระบบเองจะผิด PDPA เสียเอง

- **แจ้งและขอความยินยอม:** องค์กรต้องแจ้งพนักงานว่ามีระบบนี้ และมีนโยบายการใช้ AI ที่ชัดเจน (Acceptable Use Policy)
- **เก็บเท่าที่จำเป็น (Data Minimization):** Log ควรเก็บ "ข้อเท็จจริงของเหตุการณ์" (ใคร/เมื่อไหร่/ประเภทข้อมูล/ผลลัพธ์) ไม่ใช่เก็บเนื้อหาฉบับเต็มไว้ ยกเว้นจำเป็นและเข้ารหัส
- **สิทธิ์การเข้าถึงแบบจำกัด:** เฉพาะผู้ดูแลที่ได้รับอนุญาตเท่านั้นที่ดู Log ได้ พร้อมบันทึกว่าใครดูอะไร
- **เน้นการปกป้อง ไม่ใช่การลงโทษ:** โมดูล Coaching ช่วยให้ระบบเป็น "เครื่องมือป้องกัน" มากกว่า "เครื่องมือจับผิด" ซึ่งได้รับการยอมรับจากพนักงานมากกว่า

แนะนำให้ปรึกษาที่ปรึกษากฎหมาย/DPO ก่อนใช้งานจริง เพื่อวางนโยบายและเอกสารความยินยอมให้ถูกต้อง

## 13. ความเสี่ยงและข้อควรระวัง

- **ช่องทางหลบเลี่ยง:** พนักงานอาจใช้เครื่องส่วนตัว/มือถือถ่ายรูปหน้าจอส่งเข้า AI ซึ่งระบบบนเครื่ององค์กรจับไม่ได้ — ต้องแก้ด้วยนโยบาย + วัฒนธรรมองค์กรควบคู่ ไม่ใช่พึ่งเทคโนโลยีอย่างเดียว
- **False Positive ทำให้พนักงานหงุดหงิด:** ถ้าเตือนผิดบ่อย พนักงานจะหาทางปิด/เลี่ยงระบบ — ต้องปรับความแม่นยำและเริ่มด้วยโหมด Monitor/Warn ก่อน Block
- **ครอบคลุมเว็บ AI ที่เปลี่ยนตลอด:** เว็บ/แอป AI ใหม่เกิดขึ้นเรื่อย ๆ ต้องอัปเดตรายการปลายทางและวิธีดักจับสม่ำเสมอ
- **ต้นทุน/ความหน่วงของ AI:** เรียก LLM ทุกครั้งจะแพงและช้า — จึงต้องใช้ Local Classifier กรองก่อน เรียก AI เฉพาะเคสเสี่ยงจริง
- **ประเด็นความเชื่อใจ (Trust):** ระบบเห็นข้อมูลลับทั้งหมด ต้องมั่นคงปลอดภัยสูงสุดเอง ไม่งั้นกลายเป็นเป้าโจมตี — ความปลอดภัยของตัวแพลตฟอร์มเองคือเรื่องเป็นเรื่องตาย